



PROJECT 05 / UNIFIED EVIDENCE PORTFOLIO

Web Exposure Review

Finding a website's weak spots, explaining the business risk and defining the ethical response.

Prepared by: Anyaugo Space-Tech Ltd.

Environment: Kali, Ubuntu and OWASP Juice Shop in a VirtualBox lab

Evidence: 27 image files across nine project stages

Report date: 24 September 2026

Business question

What can an outsider discover, how serious is it, and what should the owner fix first?

Observed result

A crafted login returns an administrator-identity token. A directory listing exposes potentially sensitive filenames. Supporting captures show deployment, traffic, discovery and repeated HTTP responses.

Portfolio boundary

Controlled web-app training, not a client assessment. No cloud-platform testing or verified remediation is evidenced. Attacker scenarios and proposed client practices are labelled separately.

A website review with a business purpose

What this portfolio demonstrates

The question behind the work

If someone examined a website the way an attacker would, what could they find, how serious would it be, and what should be fixed first? Project 5 follows that question from a written scope through lab setup, traffic capture, discovery, findings and retesting.

The environment and the result

The supplied evidence uses Kali at 10.77.5.10 and an Ubuntu target at 10.77.5.20, with OWASP Juice Shop served on port 3000. Ansible deployment succeeds; the application responds; a crafted login request returns a token whose decoded payload identifies the administrator. A web-accessible /ftp directory exposes a list of potentially sensitive filenames.

How the explanations work

Each stage states the concern, the work performed and what the capture establishes. Real-life scenarios describe what an attacker might try and the resulting business risk. The ethical-hacker response explains the proportionate proof, reporting, proposed remedy and retest needed in an authorised engagement.

What is observed and what is hypothetical

Only the supplied captures are treated as observed lab results. Attacker scenarios are illustrative; they are not claims that data was stolen, a password vault was opened, or a company was compromised. Remediation and client workflows are proposals, not completed changes.

Scope of the evidence

The supplied evidence covers a local web application. No cloud account, IAM policy, storage permission review or cloud configuration test is evidenced. These would require a separately agreed scope.

Reader route

For a business review, start with the cover and Test 08. For the technical trail, follow Tests 01-07 and their original images. Test 09 explains proposed client-data and responsible-AI practices. The evidence index and PDF bookmarks support navigation.

Evidence Index

Sections, original images and page locations

Test	Section	Images	Page
01	Scope and Authorization	1	4
02	Lab Setup and Network Validation	7	6
03	Practice Application Setup	4	14
04	Web Traffic and Evidence Capture	4	19
05	Attack Surface Discovery	4	24
06	Web Application Findings	4	29
07	Findings Retest and Severity Review	2	35
08	Final Report and Client Workflow	Report	38
09	Privacy and Responsible AI Use	1	42

Evidence first

All 27 supplied images are included. Two repeated pairs are identified as reused evidence, not independent confirmations. Prepared records are labelled separately from lab screenshots.

Use the PDF bookmarks for section navigation. Wide terminal captures use landscape pages; long prepared records use larger portrait pages. Read the captions for the meaning and limits of each capture.

Introduction - page 2

Provenance and reading limits - page 44

References - page 45

Scope and Authorization

Agree the boundary before testing

Purpose and recorded scope

The prepared scope record names the agency's own VirtualBox lab, Kali, Ubuntu and OWASP Juice Shop. It also permits relevant public practice environments, including PortSwigger Academy lab instances. No evidence of Academy testing is supplied in this folder.

What the record establishes

The document sets intended activities and exclusions: inspect web traffic, map endpoints, test agreed weaknesses and report results; exclude client production systems, unapproved accounts or data, denial of service and social engineering. It is a prepared training record, not a signed client engagement letter.

Real-life scenario: an attacker's approach

A malicious actor may follow any reachable lead, including another organisation's service, without respecting ownership. A public website or a visible login page does not itself grant testing authority. The professional decision is to know exactly where permission ends.

Ethical-hacker response

Before a client assessment, agree the asset owner, exact targets, permitted methods, test window, accounts, exclusions, contacts and stop conditions in writing. If discovery leads outside that boundary, record the lead and seek a scope decision before testing it. NIST SP 800-115 supports planned assessment and rules of engagement. [R1]

How this applies to the portfolio

The Anyaugo name and logo identify the publisher. They do not create third-party permission. The supplied record is preserved as evidence of the project's stated boundary; its wording is not treated as an instruction to perform further testing.

Evidence and limitation

The following image is a prepared scope and authorization record. This report reviews existing material only; it does not establish that every configuration or action complied with the intended boundary at every moment.

Lab scope and authorization record

Prepared record / supplied original

The supplied record defines the intended training targets, approved activities and exclusions.



Anyaugo Space-Tech Ltd.
SECURITY CONSULTING | CLIENT GUIDANCE

Project 5 Scope and Authorization Record

Controlled web application exposure review lab

Test 01Neutral lab evidenceBefore testing

Introduction

Project 5 is a hands-on training exercise carried out entirely inside Anyaugo Space-Tech's own practice lab. Its purpose is to show, step by step, how the weak spots in a website are discovered, judged for seriousness, and written up in a way a business owner can understand and act on.

This is the first record in the project, and it is written **before any testing begins**. It sets the boundary of the work — what will be examined, what will deliberately be left untouched, and on whose authority the work is done. Fixing this boundary first is what allows everything that follows to be trusted as controlled, lawful and deliberate rather than random poking at systems.

Read this page as the ground rules. Every later test in Project 5 stays inside the limits set out here.

Business purpose

This record defines the agreed boundary for Project 5, a controlled training exercise that shows how a website's weak spots can be discovered, rated and reported the way an outside attacker would find them — without touching any real client system.

Authorization basis

Testing runs only in the agency's own VirtualBox lab and on public training platforms whose owners explicitly invite testing of their practice environments.

Systems in scope

Kali attacker and Ubuntu victim on the internal P05-IR-Lab network, OWASP Juice Shop on the victim, and PortSwigger Web Security Academy Lab instances.

Main outcome

Discover, rate and clearly report web weaknesses, each with a recommended fix and a retest, in plain business language.

Approved activities

- Capture and inspect web traffic with Burp Suite and curl.
- Map the lab application's pages and endpoints.
- Test for and document weaknesses in the in-scope targets only.
- Rate each finding by severity and recommend a fix.
- Report results in clear, business-readable language.

Excluded activities

- No client systems, production systems, or any website not listed above.
- No cloud accounts, credentials or data not publicly provided for practice.
- No denial of service, heavy automated scanning of public platforms, or social engineering.
- No real personal, financial or customer data.

Professional authorization note

This record does not claim client or company authorization. It documents that the exercise stays inside a controlled training lab and on platforms that publicly invite testing of their practice environments. In a real client engagement, written permission must come from the organization or authorized asset owner before any testing begins. Permission to test a system is separate from permission to share its information with an AI provider.

Industry reference

This page follows the idea of Rules of Engagement in NIST SP 800-115: define the guidelines, limits and authority for security testing before the work starts. It is a scope record for a training lab, not a legal opinion.

Evidence label: 1A-Scope-And-Authorization-Record

Status: lab scope defined before web exposure testing begins

Project 5 controlled lab evidence

Evidence note: Prepared document. It records the intended lab scope; it is not client authorization.

1A-Scope-And-Authorization-Record.png

Lab Setup and Network Validation

A known environment makes evidence interpretable

Purpose and work performed

The captures show static lab addressing, bidirectional ping checks, hostname correction, network-profile troubleshooting and two VirtualBox snapshot entries. Kali uses 10.77.5.10/24; Ubuntu uses 10.77.5.20/24 in the final displayed checks.

What the evidence shows

The first Ubuntu sequence includes a duplicate profile and an incorrect .10 address in the additional command. Later output shows the intended .20 address and successful communication. The cleanup capture prints "Duplicate profile already removed" after a fallback command; it does not independently prove which earlier deletion succeeded.

Real-life scenario: why an attacker cares

Poorly separated test and production networks can turn a low-risk practice system into a route toward valuable services. Confusing addresses or unexpected adapters can also cause a tester to contact the wrong target. That possibility is a scenario, not a demonstrated pivot in this project.

Ethical-hacker response

Confirm identity, interfaces, routes and approved reachability before sending assessment traffic. Record mistakes and the final state. Where isolation matters, check hypervisor adapters and egress as well as local ping. A successful ping proves connectivity to one address; it does not prove absence of all other paths.

Important evidence limit

The initial Kali capture shows eth1 connected with 10.0.3.15 and IPv6 addresses. Later images do not show a complete adapter and routing audit. Therefore the README's statement that the machines could reach "nothing else" is not established by these screenshots.

Snapshots and client relevance

The snapshot images show named checkpoints exist. They do not demonstrate restoration or an independent backup. In client work, a rollback plan would need an approved recovery check before disruptive activity. Seven original images follow.

TEST 02

2A | Kali addressing and reachability

Original lab screenshot

The lab profile activates on eth0 at 10.77.5.10/24 and receives replies from 10.77.5.20.

```
(project05-kali@kali)~$ nmcli device status
ip -br addr
DEVICE  TYPE      STATE      CONNECTION
eth1    ethernet  connected  Wired connection 1
lo      loopback  connected (externally)  lo
eth0    ethernet  disconnected  --
lo      UNKNOWN  127.0.0.1/8  ::1/128
eth0    UP
eth1    UP        10.0.3.15/24  fd17:625c:f037:3:606e:d353:8f0b:7d77/64  fd17:625c:f037:3:a00:27ff:fe51:801a/64  fe80::a00:27ff:fe51:801a/64

(project05-kali@kali)~$ sudo nmcli con add type ethernet ifname eth0 con-name p05-lab ipv4.method manual ipv4.addresses 10.77.5.10/24 ipv6.m
ethod disabled
sudo nmcli con up p05-lab
ip -br addr show eth0
ping -c 3 10.77.5.20
[sudo] password for project05-kali:
Connection 'p05-lab' (273cd0e6-96dc-4252-8cb8-8d0fe3e51ee6) successfully added.
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/5)
eth0    UP        10.77.5.10/24
PING 10.77.5.20 (10.77.5.20) 56(84) bytes of data.
64 bytes from 10.77.5.20: icmp_seq=1 ttl=64 time=7.11 ms
64 bytes from 10.77.5.20: icmp_seq=2 ttl=64 time=1.47 ms
64 bytes from 10.77.5.20: icmp_seq=3 ttl=64 time=1.39 ms
```

Evidence note: The earlier interface output also shows connected eth1 at 10.0.3.15. This image does not prove complete isolation.

Test-2A-kali-static-ip-eth0-ping-victim.png

TEST 02

2B | Ubuntu configuration and duplicate profile

Original lab screenshot

The capture records the intended .20 address, followed by another profile command using .10 and a duplicate-name warning.

```
lab-admin@project05-ubuntu-victim:~$ sudo nmcli con add type ethernet ifname enp0s3 con-name "P05-IR-Lab" ip4 10.77.5.20/24
sudo nmcli con up "P05-IR-Lab"
ip -br addr show enp0s3
[sudo] password for lab-admin:
Connection 'P05-IR-Lab' (57b75658-153f-43de-a397-b1d72b6a809d) successfully added.
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/72)
enp0s3          UP          10.77.5.20/24 fe80::a70d:da54:f62:a324/64
lab-admin@project05-ubuntu-victim:~$ ip -br link
lo              UNKNOWN    00:00:00:00:00:00 <LOOPBACK,UP,LOWER_UP>
enp0s3          UP          08:00:27:81:b0:1e <BROADCAST,MULTICAST,UP,LOWER_UP>
enp0s8          UP          08:00:27:72:ed:95 <BROADCAST,MULTICAST,UP,LOWER_UP>
lab-admin@project05-ubuntu-victim:~$ sudo nmcli con add type ethernet ifname eth0 con-name "P05-IR-Lab" ip4 10.77.5.10/24
sudo nmcli con up "P05-IR-Lab"
Warning: There is another connection with the name 'P05-IR-Lab'. Reference the connection by its uuid 'a758111c-3193-4843-95bf-3ed841951aff'
Connection 'P05-IR-Lab' (a758111c-3193-4843-95bf-3ed841951aff) successfully added.
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/73)
```

Evidence note: This is troubleshooting evidence. The later address and ping checks provide the clearer record of the resulting lab state.

Test-2B-ubuntu-static-ip-enp0s3-with-duplicate-profile-error.png

2C-1 | Profile cleanup and Ubuntu address

Original lab screenshot

The displayed profile list and interface output show Ubuntu at 10.77.5.20/24.

```
lab-admin@project05-ubuntu-victim:~$ printf '=== Project 5 Test 02: duplicate profile cleanup =
===\n'
date -u
hostname
whoami

printf '\n=== Remove stray duplicate profile (if still present) ===\n'
sudo nmcli con delete a758111c-3193-4843-95bf-3ed841951aff 2>/dev/null || echo 'Duplicate profi
le already removed.'

printf '\n=== Remaining network profiles ===\n'
nmcli -f NAME,UUID,DEVICE con show

printf '\n=== Lab interface address ===\n'
ip -br addr show enp0s3

printf '\n=== Reach Kali attacker inside lab ===\n'
ping -c 3 10.77.5.10
=== Project 5 Test 02: duplicate profile cleanup ===
Wed Sep 23 05:14:32 PM UTC 2026
project05-ubuntu-victim
lab-admin

=== Remove stray duplicate profile (if still present) ===
[sudo] password for lab-admin:
Duplicate profile already removed.

=== Remaining network profiles ===
NAME                UUID                                DEVICE
netplan-enp0s8      9a683faa-2cc7-384f-9230-8beaf91f9f29  enp0s8
P05-IR-Lab          57b75658-153f-43de-a397-b1d72b6a809d  enp0s3
lo                   0a6b51c0-229e-4b52-b53a-f3401004c714  lo
netplan-enp0s3      1eef7e45-3b9d-3043-bee3-fc5925c90273  --

=== Lab interface address ===
enp0s3                UP                10.77.5.20/24 fe80::a70d:da54:f62:a324/64
```

Evidence note: The fallback text says the duplicate was already removed; the visible command suppresses errors. The final address is the directly observable result.

Test-2C-1-ubuntu-duplicate-profile-removed.png

TEST 02

2C-2 | Ubuntu reaches Kali

Original lab screenshot

Three packets sent to 10.77.5.10 receive three replies, with 0% packet loss.

```
=== Lab interface address ===
enp0s3          UP          10.77.5.20/24 fe80::a70d:da54:f62:a324/64

=== Reach Kali attacker inside lab ===
PING 10.77.5.10 (10.77.5.10) 56(84) bytes of data.
64 bytes from 10.77.5.10: icmp_seq=1 ttl=64 time=2.06 ms
64 bytes from 10.77.5.10: icmp_seq=2 ttl=64 time=1.23 ms
64 bytes from 10.77.5.10: icmp_seq=3 ttl=64 time=1.25 ms

--- 10.77.5.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 1.225/1.509/2.056/0.386 ms
lab-admin@project05-ubuntu-victim:~$
```

Evidence note: This confirms the displayed internal connection at capture time. It is not an egress or segmentation audit.

Test-2C-2-ubuntu-ping-kali.png

2D | Kali identity and reciprocal connection

Original lab screenshot

The hostname and hosts entry identify project05-kali; eth0 has .10 and the .20 target returns three replies.

```
(project05-kali@project05-kali)-[~]
$ printf '=== Project 5 Test 02: Kali hostname corrected ===\n'
date -u
hostname
whoami
grep project05 /etc/hosts

printf '\n=== Lab interface and reach to Ubuntu victim ===\n'
ip -br addr show eth0
ping -c 3 10.77.5.20
=== Project 5 Test 02: Kali hostname corrected ===
Wed 23 Sep 2026 17:05:40 UTC
project05-kali
project05-kali
127.0.1.1      project05-kali

=== Lab interface and reach to Ubuntu victim ===
eth0          UP          10.77.5.10/24
PING 10.77.5.20 (10.77.5.20) 56(84) bytes of data.
64 bytes from 10.77.5.20: icmp_seq=1 ttl=64 time=1.48 ms
64 bytes from 10.77.5.20: icmp_seq=2 ttl=64 time=1.13 ms
64 bytes from 10.77.5.20: icmp_seq=3 ttl=64 time=1.28 ms

--- 10.77.5.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 1.130/1.295/1.480/0.143 ms

(project05-kali@project05-kali)-[~]
$
```

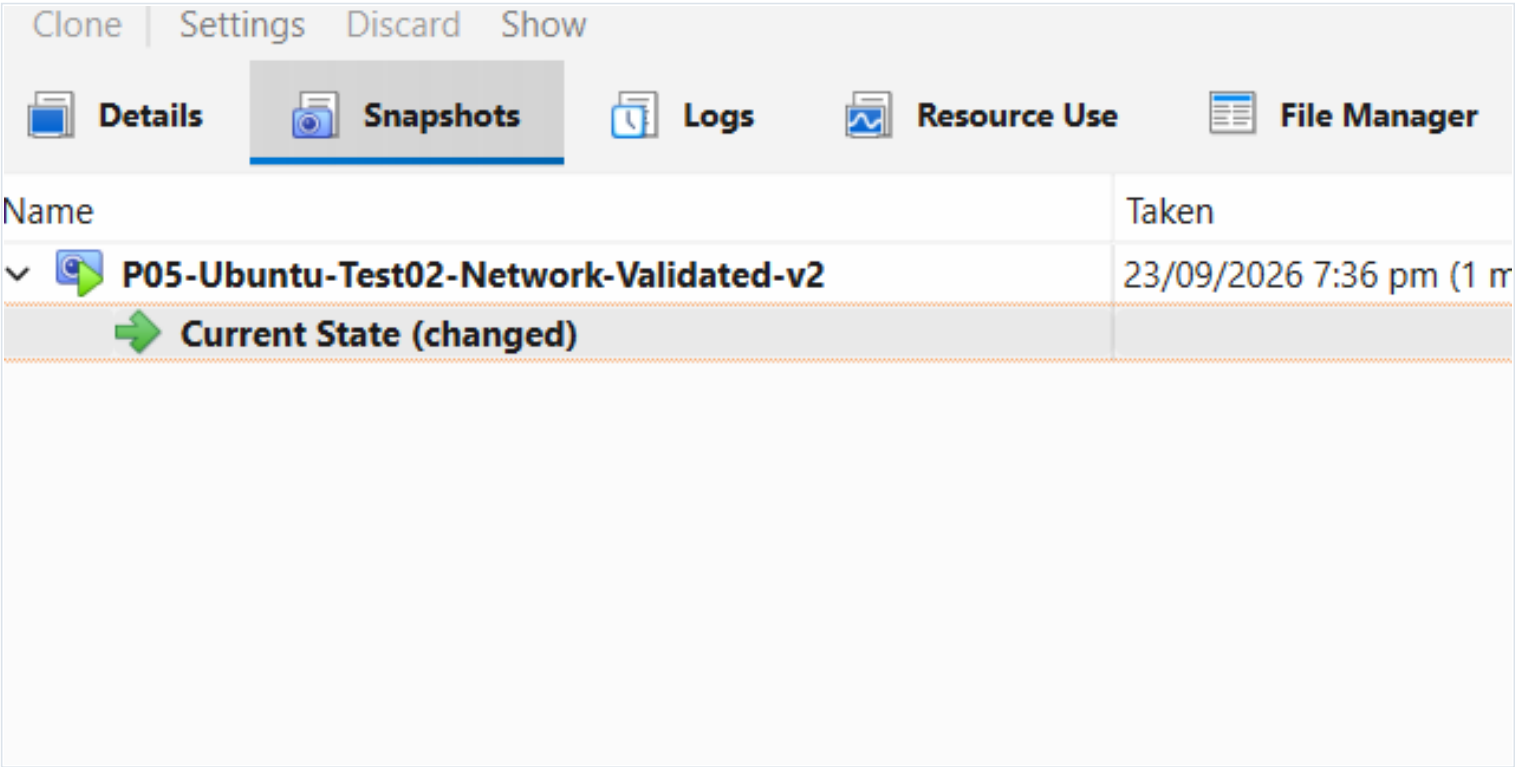
Evidence note: Together with 2C-2, this supports bidirectional lab reachability. Only the displayed interface is checked here.

Test-2D-kali-hostname-corrected-ping-victim.png

2E-1 | Ubuntu checkpoint recorded

Original lab screenshot

VirtualBox lists P05-Ubuntu-Test02-Network-Validated-v2 above the current state.



Evidence note: A snapshot name records an intended checkpoint. No snapshot restoration is shown.

Test-2E-1-ubuntu-test02-network-validated-v2-snapshot.png

2E-2 | Kali checkpoint recorded

Original lab screenshot

VirtualBox lists P05-Kali-Test02-Network-Validated-v2 above the current state.

 Details

 Snapshots

 Logs

 Resource Use

 File Manager

Name	Taken
  P05-Kali-Test02-Network-Validated-v2	23/09/2026 7:35 pm (3 mi
 Current State (changed)	

Evidence note: This is evidence of a listed checkpoint, not a tested recovery or independent backup.

Test-2E-2-kali-test02-network-validated-v2-snapshot.png

Practice Application Setup

Deploy the target and verify that it responds

Purpose and work performed

Kali uses Ansible against Ubuntu. The first capture reports a successful Ansible ping. The deployment playbook installs prerequisites and Docker, pulls Juice Shop and starts its container. The recap shows ok=6, changed=4, unreachable=0 and failed=0.

What the evidence shows

A request to `http://10.77.5.20:3000` receives HTTP 200 and a browser displays the Juice Shop storefront. Together these show deployment and basic application reachability at capture time. Ansible's ping checks its remote execution path; it is distinct from the network pings in Test 02.

Real-life scenario: automation access

A business may use automation to configure many servers consistently. If an attacker obtains that automation account or its secrets, the same access could be misused to change several systems. This scenario explains the importance of the channel; no stolen automation credentials or fleet compromise were demonstrated here.

Ethical-hacker response

Use only the provided lab account and approved target. In a client review, inspect the automation account's permissions, secret handling and change records within scope. Recommend restricted access and reviewed deployment changes; do not demonstrate harmful fleet-wide changes just to prove access.

Evidence limit and repeatability

The screenshot shows a successful playbook run, but the playbook and inventory files themselves are not supplied. A fresh rebuild or recovery has not been demonstrated. The browser capture establishes the storefront, not the health of every feature or a secure deployment.

Business meaning

The test establishes a working target before assessing its weaknesses. OWASP Juice Shop is used here as the deliberately vulnerable practice application described in the project materials. Four images follow.

TEST 03

3A | Ansible remote execution succeeds

Original lab screenshot

The victim at 10.77.5.20 returns SUCCESS and ping: pong, with changed: false.

```
(project05-kali㉿project05-kali)-[~/project05-ansible]
$ ssh-keyscan -H 10.77.5.20 >> ~/.ssh/known_hosts
ansible -i inventory.ini victim -m ping --ask-pass
SSH password:
10.77.5.20 | SUCCESS => {
    "changed": false,
    "ping": "pong"
}

(project05-kali㉿project05-kali)-[~/project05-ansible]
$
```

Evidence note: This supports Ansible connectivity using supplied credentials. It does not demonstrate exploitation.

Test-3A-ansible-ping-victim-success.png

3B | Juice Shop deployment completes

Original lab screenshot

The visible playbook recap reports six successful tasks, four changes, no unreachable hosts and no failures.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ ansible-playbook -i inventory.ini deploy-juiceshop.yml --ask-pass --ask-become-pass
SSH password:
BECOME password[defaults to SSH password]:

PLAY [Deploy OWASP Juice Shop on the Project 5 victim] *****

TASK [Gathering Facts] *****
ok: [10.77.5.20]

TASK [Install prerequisite packages] *****
changed: [10.77.5.20]

TASK [Install Docker from Ubuntu repository] *****
changed: [10.77.5.20]

TASK [Ensure Docker service is running and enabled] *****
ok: [10.77.5.20]

TASK [Pull the Juice Shop image] *****
changed: [10.77.5.20]

TASK [Run the Juice Shop container] *****
changed: [10.77.5.20]

PLAY RECAP *****
10.77.5.20 : ok=6 changed=4 unreachable=0 failed=0 skipped=0 res
cued=0 ignored=0

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: The run output is supplied; the playbook source and an independent rebuild test are not.

Test-3B-ansible-playbook-juiceshop-deployed.png

3C-1 | The web application responds

Original lab screenshot

curl receives HTTP 200 from the Ubuntu target on port 3000, with response headers and HTML content type.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ curl -I http://10.77.5.20:3000
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Wed, 23 Sep 2026 23:56:21 GMT
ETag: W/"24b1-1a0d0b2e96b"
Content-Type: text/html; charset=UTF-8
Content-Length: 9393
Vary: Accept-Encoding
Date: Thu, 24 Sep 2026 00:08:41 GMT
Connection: keep-alive
Keep-Alive: timeout=5

(project05-kali@project05-kali)-[~/project05-ansible]
$ |
```

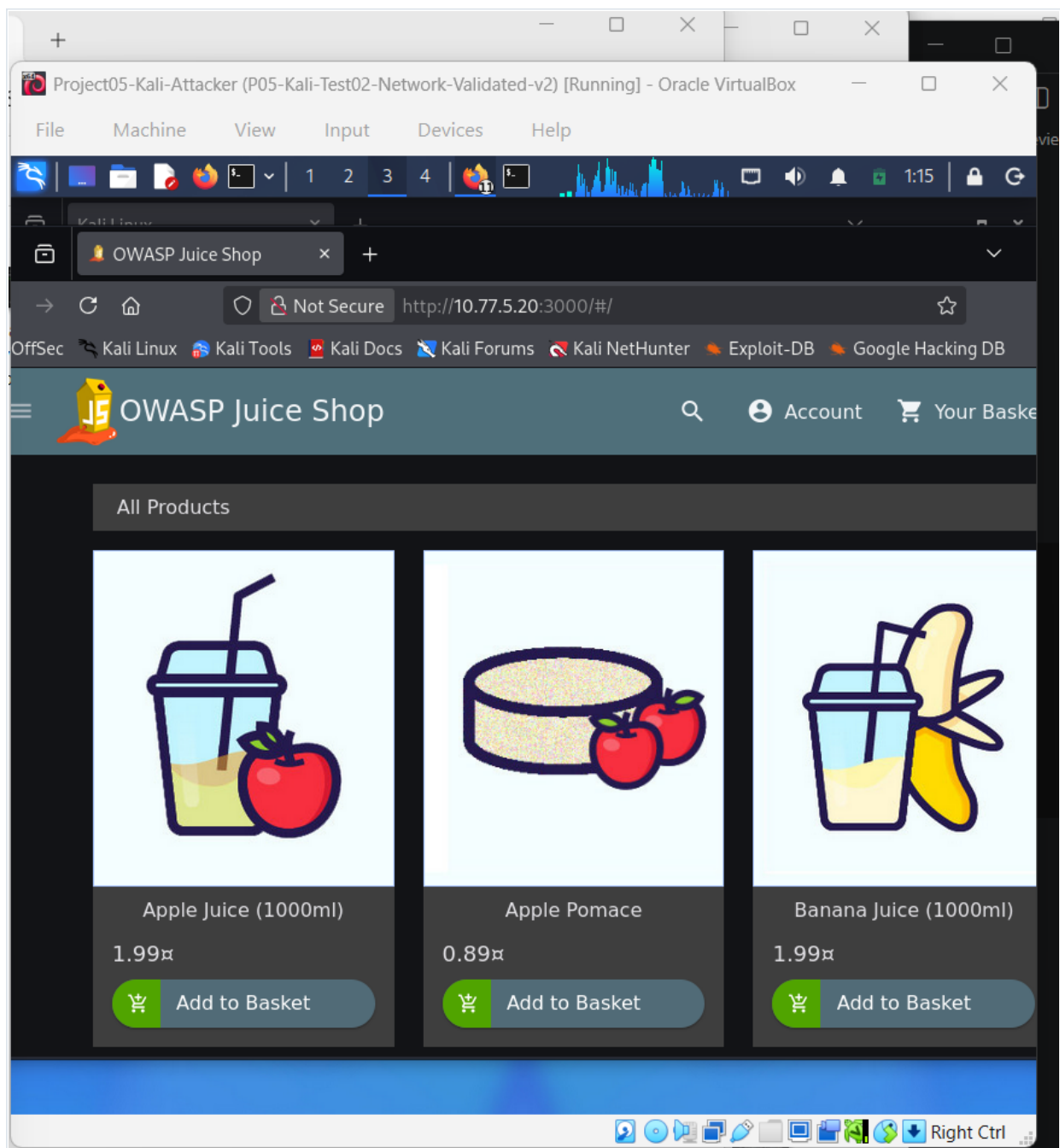
Evidence note: This verifies a response from the root page. It is not a full functional or security test.

Test-3C-1-juiceshop-reachable-from-kali.png

3C-2 | Storefront visible in the lab browser

Original lab screenshot

The browser displays the Juice Shop product catalogue at the lab address.



Evidence note: The visible browser page corroborates basic application availability. No real customer transaction is shown.

Test-3C-2-juiceshop-storefront-in-browser.png

Web Traffic and Evidence Capture

Read what the application actually sends

Purpose and recorded sequence

curl captures the root response, creates a practice account with HTTP 201, logs in with HTTP 200 and extracts a JWT payload. The customer token includes a password-hash field, role and account metadata. The screenshot contains lab credentials and tokens; they are not repeated in the report prose.

Real-life scenario: information exposed to the browser

An attacker who obtains a token can inspect a readable payload for useful account information. A password hash could assist offline guessing, but reading a token is not proof that it can be forged. For a business, unnecessary disclosure increases the consequences of a token leak.

Ethical-hacker response to token disclosure

Record the unnecessary field using a controlled account. Recommend retaining only claims needed by the application and removing password hashes. A later test should inspect newly issued tokens and separately check signature and authorisation enforcement. No signature bypass, token forgery or successful hash cracking is shown here. [R4]

Headers: observations before conclusions

The root response includes X-Content-Type-Options and X-Frame-Options, while CSP and HSTS are not visible. The test uses plain HTTP; an absent HSTS header here is not proof of an HTTPS-site configuration defect. A production review would assess HTTPS behaviour and an appropriate CSP in context. [R5]

Cross-origin policy

Access-Control-Allow-Origin: * is visible. This is an observation requiring endpoint-specific review, not proof of cross-origin account theft. Determine which data is intentionally public and restrict origins where cross-origin access is required for sensitive services. [R6]

Client meaning and evidence limit

These captures teach how to turn traffic into verifiable observations without overstating impact. Test 06 demonstrates a separate SQL-injection login bypass; it does not establish that the token-disclosure issue was independently exploited. Four images follow.

4A | Request and response headers

Original lab screenshot

The verbose capture shows Kali connecting to the lab target, receiving HTTP 200 and displaying response headers.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ curl -v http://10.77.5.20:3000/ -o /dev/null
* Trying 10.77.5.20:3000...
* Established connection to 10.77.5.20 (10.77.5.20 port 3000) from 10.77.5.10 port 55342
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
  0         0     0      0      0      0      0      0      0      0
> GET / HTTP/1.1
> Host: 10.77.5.20:3000
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Access-Control-Allow-Origin: *
< X-Content-Type-Options: nosniff
< X-Frame-Options: SAMEORIGIN
< Feature-Policy: payment 'self'
< X-Recruiting: /#/jobs
< Accept-Ranges: bytes
< Cache-Control: public, max-age=0
< Last-Modified: Wed, 23 Sep 2026 23:56:21 GMT
< ETag: W/"24b1-1a0d0b2e96b"
< Content-Type: text/html; charset=UTF-8
< Content-Length: 9393
< Vary: Accept-Encoding
< Date: Thu, 24 Sep 2026 11:07:28 GMT
< Connection: keep-alive
< Keep-Alive: timeout=5
<
{ [9393 bytes data]
100  9393 100  9393   0      0  91857    0      0
* Connection #0 to host 10.77.5.20:3000 left intact

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: Some security headers are present. CSP and HSTS are not displayed; the request is HTTP, and wildcard CORS alone does not prove data theft.

Test-4A-curl-verbose-headers.png

4B-1 | Practice account creation

Original lab screenshot

The registration request receives HTTP 201 Created and a response identifying a customer account.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ curl -s -i -X POST http://10.77.5.20:3000/api/Users \
  -H "Content-Type: application/json" \
  -d '{"email":"[email protected]","password":"Anyaugo123!","passwordRepeat":"Anyaugo123!","securityQuestion":{"id":1},"securityAnswer":"lab"}' \
  | tee Test-4B-1-curl-register.txt
HTTP/1.1 201 Created
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: /api/Users/25
Content-Type: application/json; charset=utf-8
Content-Length: 308
ETag: W/"134-t8Z1tiNmNUA6mWFF7S7XUo/Zujs"
Vary: Accept-Encoding
Date: Thu, 24 Sep 2026 12:03:41 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"status":"success","data":{"username":"","role":"customer","deluxeToken":"","lastLoginIp":"0.0.0.0","profileImage":"/assets/public/images/uploads/default.svg","isActive":true,"id":25,"email":"[email protected]","updatedAt":"2026-09-24T12:03:41.359Z","createdAt":"2026-09-24T12:03:41.359Z","deletedAt":null}}

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: This is controlled test-data creation. It is a deliberate application-state change, so the exercise should not be described as entirely read-only.

Test-4B-1-curl-register.png

4B-2 | Normal login returns a token

The practice account receives HTTP 200 and an authentication token.

Evidence note: This establishes the normal login baseline. The supplied screenshot is retained unchanged and includes lab authentication material.

Project 5 | Web Exposure Review | Controlled lab

TEST 04

4B-3 | Customer token payload

Original lab screenshot

The decoded payload shows the customer role and a password-hash field among account attributes.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ grep -o '"token":"[^"]*"' Test-4B-2-curl-login-token.txt | cut -d'"' -f4 | cut -d. -f2 | ba
se64 -d 2>/dev/null | tee Test-4B-3-jwt-decoded.txt; echo
{"data":{"id":25,"username":"","email":"[email protected]","password":"a68fa865ce0dd448bce17875
20e598c4","role":"customer","deluxeToken":"","lastLoginIp":"0.0.0.0","profileImage":"/assets/pu
blic/images/uploads/default.svg","totpSecret":"","isActive":true,"createdAt":"2026-09-24 12:03:
41.359 +00:00","updatedAt":"2026-09-24 12:03:41.359 +00:00","deletedAt":null},"bid":6,"iat":179
0252182}

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: Readable claims are not proof of forgery. The concern here is unnecessary sensitive content, not the mere presence of a role claim.

Test-4B-3-jwt-decoded.png

Attack Surface Discovery

Turn endpoint leads into validated observations

Purpose and work performed

ffuf probes common paths and filters responses of 9,393 bytes, matching the root page size shown earlier. The displayed results include /ftp, /robots.txt, redirects and several error responses. curl then retrieves robots.txt, and a local text-processing command lists names from the captured /ftp response.

What the evidence shows

The screenshots show the size filter in use and the resulting leads. The final ffuf status reaches 4,614 of 4,614 wordlist entries but reports 1,074 errors. The folder does not contain the raw JSON or text output referenced in the commands. These captures support discovery activity, not an exhaustive inventory.

Real-life scenario: following a public clue

A company might list an internal-looking path in robots.txt to discourage search indexing. An attacker could read that file, visit the path and look for sensitive material. Here, "Disallow: /ftp" is a useful lead; it is not an access restriction or proof of a weakness by itself.

Ethical-hacker response

Check response bodies and expected behaviour rather than counting every HTTP 200 or 500 as a real endpoint or finding. Use agreed traffic limits, inspect error-heavy results and manually validate important leads. Do not extend discovery into unapproved assets. A scan with errors must retain that limitation.

The step from discovery to a finding

The /ftp filename list raises a specific concern because names include backups and a .kdbx file. An ethical tester would establish permitted access and sensitivity with the minimum necessary evidence before rating actual exposure. Further downloading or cracking is not demonstrated in this portfolio. [R3]

Evidence reuse

The robots.txt and filename-list images are reused byte-for-byte in Test 06. They appear in both sections to preserve the project sequence, but are not counted as independent confirmations. Four image files follow.

5A-1 | Size-filtered discovery

Original lab screenshot

ffuf filters response size 9393 and returns leads including /ftp, /assets and /promotion.

```
(project05-kali@project05-kali)~[~/project05-ansible]
$ ffuf -u http://10.77.5.20:3000/FUZZ \
-w /usr/share/wordlists/dirb/common.txt \
-fs 9393 \
-o Test-5A-ffuf-directory-discovery.json -of json \
| tee Test-5A-ffuf-directory-discovery.txt
```



```
v2.1.0-dev
```

```
-----
:: Method      : GET
:: URL         : http://10.77.5.20:3000/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Output file : Test-5A-ffuf-directory-discovery.json
:: File format : json
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 9393
-----
```

```
api      [Status: 500, Size: 2408, Words: 210, Lines: 50, Duration: 281ms]
apis     [Status: 500, Size: 2410, Words: 210, Lines: 50, Duration: 281ms]
assets   [Status: 301, Size: 156, Words: 6, Lines: 11, Duration: 206ms]
ftp      [Status: 200, Size: 11307, Words: 1579, Lines: 358, Duration: 1084ms]
media    [Status: 301, Size: 155, Words: 6, Lines: 11, Duration: 227ms]
profile  [Status: 500, Size: 1043, Words: 153, Lines: 50, Duration: 1104ms]
promotion [Status: 200, Size: 5863, Words: 536, Lines: 180, Duration: 1669ms]
```

Evidence note: A filtered result is a lead. HTTP status, response body and access behaviour need interpretation before declaring a finding.

Test-5A-1-ffuf-filtered-attack-surface.png

TEST 05

5A-2 | Discovery completion and errors

Original lab screenshot

The final display reaches 4614/4614 entries and records 1074 errors.

```
promotion [Status: 200, Size: 5863, Words: 536, Lines: 180, Duration: 1669ms]
redirect [Status: 500, Size: 2531, Words: 219, Lines: 50, Duration: 417ms]
rest [Status: 500, Size: 2410, Words: 210, Lines: 50, Duration: 268ms]
restored [Status: 500, Size: 2418, Words: 210, Lines: 50, Duration: 255ms]
restore [Status: 500, Size: 2416, Words: 210, Lines: 50, Duration: 256ms]
restaurants [Status: 500, Size: 2424, Words: 210, Lines: 50, Duration: 265ms]
restricted [Status: 500, Size: 2422, Words: 210, Lines: 50, Duration: 255ms]
robots.txt [Status: 200, Size: 28, Words: 3, Lines: 2, Duration: 785ms]
seccode [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 950ms]
second [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 950ms]
secondary [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 949ms]
secret [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 946ms]
secrets [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 941ms]
section [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 937ms]
sections [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1899ms]
:: Progress: [4614/4614] :: Job [1/1] :: 1 req/sec :: Duration: [0:10:08] :: Errors: 1074 ::

(project05-kali@project05-kali)-[~/project05-ansible]
$ |
```

Evidence note: The run is not an error-free inventory. Some apparent endpoints return errors or empty responses and require follow-up.

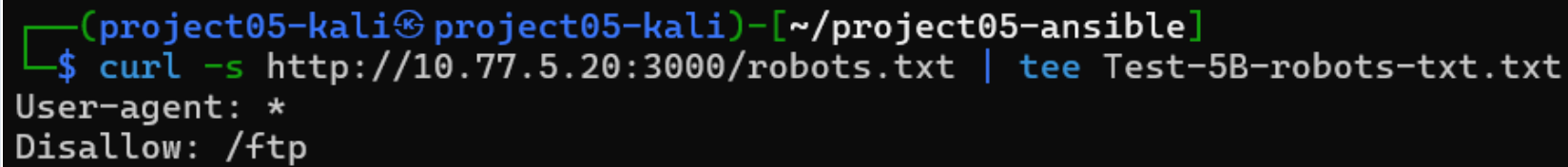
Test-5A-2-ffuf-attack-surface-endpoints.png

TEST 05

5B | robots.txt identifies /ftp

Original lab screenshot

The response contains User-agent: * and Disallow: /ftp.

A terminal window with a dark background. The prompt is (project05-kali@project05-kali)-[~/project05-ansible]. The command entered is \$ curl -s http://10.77.5.20:3000/robots.txt | tee Test-5B-robots-txt.txt. The output is User-agent: * and Disallow: /ftp.

```
(project05-kali@project05-kali)-[~/project05-ansible]  
$ curl -s http://10.77.5.20:3000/robots.txt | tee Test-5B-robots-txt.txt  
User-agent: *  
Disallow: /ftp
```

Evidence note: This supplies a discovery lead. It does not deny HTTP access. The same image is reused as Test 6B-1.

Test-5B-robots-txt.png

TEST 05

5C | Filenames from the exposed directory

Original lab screenshot

The extracted list includes .bak files and incident-support.kdbx alongside other names.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ grep -oP 'title="\K[^"]+' Test-5C-ftp-directory-listing.txt | sort -u | tee Test-5C-ftp-files-only.txt
acquisitions.md
announcement_encrypted.md
coupons_2013.md.bak
eastere.gg
encrypt.pyc
incident-support.kdbx
legal.md
package.json.bak
package-lock.json.bak
quarantine
suspicious_errors.yml

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: The capture shows filenames extracted from a saved listing. It does not show the contents or successful download of each file. Reused as Test 6B-2.

Test-5C-ftp-files-only.png

Administrator Login Bypass

Recorded severity: Critical | demonstrated in the lab

Observed evidence

A crafted request to `/rest/user/login` receives HTTP 200 and an authentication token. The next capture decodes that returned token and displays id 1, `admin@juice-sh.op` and role `admin`. Together the images support an administrator-identity token being issued without the legitimate administrator password.

Real-life scenario: the potential consequence

On a business website, bypassing login could allow an attacker to attempt privileged operations, view customer information or change records. The exact impact depends on which server-side actions the session can perform. No customer-data extraction, record change, persistence or operating-system takeover is demonstrated here.

How an ethical hacker would handle it

Preserve the request, response and account identity as the minimum convincing proof. Escalate the finding through the agreed contact, explaining why privileged authentication is affected. Further privilege validation should use an approved harmless action; unnecessary access to business records adds risk without improving this evidence.

Proposed remedy and owner

The application developer should replace unsafe query construction with parameterised queries so supplied values remain data, and review related authentication queries. The database account should have only necessary privileges. Treat this as a root-cause repair, not simply blocking one input string. [R2]

What a meaningful retest would show

After an approved fix, the previous bypass input must not produce an authenticated session. A legitimate test account should still work. Capture the response body and session behaviour, and verify a harmless protected action if authorised. An HTTP status code alone is insufficient.

Rating and assurance boundary

Critical is the qualitative rating recorded in Test 7B, reflecting the potential impact of administrator authentication bypass. No CVSS vector was supplied. This report retains that rating with its evidence limits; it does not claim full system takeover or verified access to every administrative function.

Exposed Directory and Sensitive Filenames

Recorded severity: High | content access not fully evidenced

Observed evidence

The discovery output reports /ftp returning HTTP 200. robots.txt points to that path, and the supplied listing extraction includes coupons_2013.md.bak, package.json.bak, package-lock.json.bak and incident-support.kdbx. The two Test 6B images repeat the Test 05 captures.

Real-life scenario: following the filenames

An attacker could use a backup filename to seek configuration details or a password-vault file for attempted offline guessing. Exposure of a filename does not guarantee download access, valuable contents or a crackable vault. Those are possible follow-on risks, not completed actions shown here.

How an ethical hacker would handle it

Document the accessible listing and why the names warrant urgent review. If explicitly within scope, test a minimal approved file request and record access and content sensitivity without collecting unnecessary data. Ask the owner to assess whether any real secrets were exposed; do not download everything or attempt cracking without an agreed reason and scope.

Proposed remedy and owner

The application or hosting owner should remove backups and secret-bearing artifacts from web-served locations and enforce access control where files must remain available. Disabling directory indexing alone is insufficient if a known direct file URL still works. Review the deployment process that placed those files there. [R3]

What a meaningful retest would show

Check both directory browsing and authorised direct-file test cases from an unauthenticated session. If secret exposure is confirmed, the owner should assess credential rotation and relevant access records. No remedy, rotation, file download or vault opening is evidenced in this project.

Rating and assurance boundary

High is the supplied analyst rating. The visible filename exposure is confirmed, but the claimed sensitivity and downloadability require additional validation. Treat the rating as provisional for content exposure rather than inventing evidence of credential compromise. Four source images for Findings 6A and 6B follow.

The displayed login request receives HTTP 200 and a token associated with the administrator email.

```

(project05-kali@project05-kali)~[~/project05-ansible]
$ curl -s -i -X POST http://10.77.5.20:3000/rest/user/login \
-H "Content-Type: application/json" \
-d '{"email":""," OR 1=1--","password":"anything"}' \
| tee Test-6A-sqli-login-bypass.txt
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 784
ETag: W/"310-YR6sNLqmN7NbvxU+uJOYrY5anV0"
Vary: Accept-Encoding
Date: Thu, 24 Sep 2026 17:34:50 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"authentication":{"token":"eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJkYXRhIjpw7ImlkIjoxLCJ1c2VybmFtZSI6IiIsImVtYWlsIjoiYWRtaW5AanVpY2U2c2gub3AiLCJwYXNzd29yZCI6IjAxOTIwMjNhN2JiZDczMjUwNTE2ZjA2OVRmMThiNTAwIiwicm9sZSI6ImFkbWwluIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3VwbG9hZHMvZGVmYXVsdEFkbWwluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZlZSI6dHJ1ZSwiY3JlYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOS0yNCANdOxMD01NS4zOTEgKzAwOjAwIiwiaXNzIGVsdXh1VG9rZW4iOiIiLCJyZXN0TG9naW5JcCI6IiIsInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsaWMvaW1hZ2VzL3V
```

Test-6A-1-sqli-login-bypass-200-token.png

TEST 06

6A-2 | Returned token identifies administrator

Original lab screenshot

The decoded payload displays the administrator account and role admin.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ grep -o '"token":"[^"]*"' Test-6A-sqli-login-bypass.txt | cut -d'"' -f4 | cut -d. -f2 | bas
e64 -d 2>/dev/null | tee Test-6A-2-sqli-admin-token-decoded.txt; echo
{"data":{"id":1,"username":"","email":"admin@juice-sh.op","password":"0192023a7bbd73250516f069d
f18b500","role":"admin","deluxeToken":"","lastLoginIp":"","profileImage":"assets/public/images/
uploads/defaultAdmin.png","totpSecret":"","isActive":true,"createdAt":"2026-09-24 14:10:55.391
+00:00","updatedAt":"2026-09-24 14:10:55.391 +00:00","deletedAt":null},"bid":1,"iat":1790271290
}

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: Together with 6A-1, this supports the login bypass. Decoding is not a signature-verification test or evidence of operating-system access.

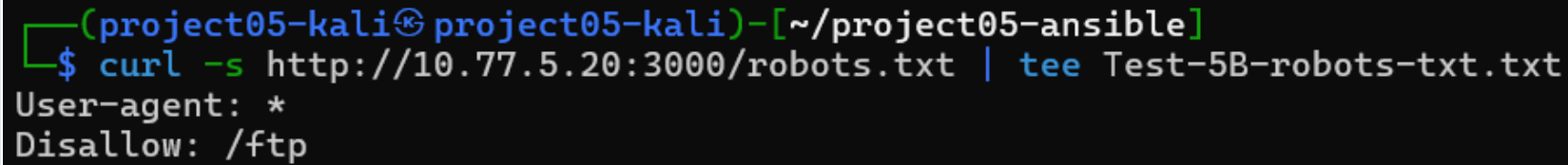
Test-6A-2-sqli-admin-token-decoded.png

TEST 06

6B-1 | Public clue to the directory

Original lab screenshot

robots.txt explicitly names /ftp.

A terminal window with a dark background. The prompt is '(project05-kali@project05-kali)-[~/project05-ansible]'. The command '\$ curl -s http://10.77.5.20:3000/robots.txt | tee Test-5B-robots-txt.txt' is entered. The output is 'User-agent: *' and 'Disallow: /ftp'.

```
(project05-kali@project05-kali)-[~/project05-ansible]  
$ curl -s http://10.77.5.20:3000/robots.txt | tee Test-5B-robots-txt.txt  
User-agent: *  
Disallow: /ftp
```

Evidence note: This is byte-identical to Test 5B. It supports the same discovery lead and is not a new retest.

Test-6B-1-robots-disallow-ftp.png

TEST 06

6B-2 | Directory filename exposure

Original lab screenshot

The extracted directory names include backup-like files and a .kdbx filename.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ grep -oP 'title="\K[^"]+' Test-5C-ftp-directory-listing.txt | sort -u | tee Test-5C-ftp-files-only.txt
acquisitions.md
announcement_encrypted.md
coupons_2013.md.bak
eastere.gg
encrypt.pyc
incident-support.kdbx
legal.md
package.json.bak
package-lock.json.bak
quarantine
suspicious_errors.yml

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: This is byte-identical to Test 5C. Individual file access, contents and password-vault compromise are not shown.

Test-6B-2-ftp-directory-exposed.png

Findings Retest and Severity Review

Separate repeated responses from a verified repair

Purpose and recorded result

The retest repeats the crafted login request and a request to /ftp/. Both display HTTP 200. A separate prepared review records Critical for login bypass, High for exposed files, Medium for token data, Low for missing headers and wildcard CORS, and Informational for the robots.txt path.

What the retest actually establishes

The commands discard response bodies. The capture therefore shows repeated HTTP response status, but does not show a fresh token, decoded role, privileged action, directory content or individual file download. Test 06 remains the stronger evidence for administrator identity issuance.

Real-life scenario: why status-only checks can mislead

A business application can return a successful HTTP status while displaying an error or rejecting access in its response body. An attacker may investigate that difference; a professional assessor must also check actual behaviour before claiming either continued exploitation or successful repair.

Ethical-hacker response

Compare the post-change result against a defined acceptance criterion: no unauthorised session, no unintended file access and normal authorised use preserved. Record before-and-after evidence and any residual risk. This project contains no remediation deployment or successful fix verification.

How the ratings will be used

The prepared review uses impact and ease of exploitation as a qualitative guide, not a numeric CVSS calculation. This report preserves those supplied ratings while qualifying the evidence. The file-exposure impact remains provisional; header and CORS observations need deployment-specific context.

Correction to the prepared narrative

The source page states that a deliberately vulnerable application "cannot be patched". The supported statement is narrower: no patch or remediation is evidenced in this exercise. A practice application's intended vulnerability does not make correction technically impossible. The original page follows unchanged, with this explanatory qualification.

TEST 07

7A | Repeated HTTP responses

Original lab screenshot

The crafted login request and /ftp/ request both return HTTP 200 in the displayed retest.

```
(project05-kali@project05-kali)-[~/project05-ansible]
$ echo "=== RETEST 6A: SQLi admin login bypass ===" ; \
curl -s -o /dev/null -w "HTTP %{http_code}\n" -X POST http://10.77.5.20:3000/rest/user/login \
-H "Content-Type: application/json" \
-d '{"email":"' OR 1=1--","password":"x"}' ; \
echo "=== RETEST 6B: /ftp directory still exposed ===" ; \
curl -s -o /dev/null -w "HTTP %{http_code}\n" http://10.77.5.20:3000/ftp/ \
| tee Test-7A-findings-retest.txt
=== RETEST 6A: SQLi admin login bypass ===
HTTP 200
=== RETEST 6B: /ftp directory still exposed ===
HTTP 200

(project05-kali@project05-kali)-[~/project05-ansible]
$
```

Evidence note: Bodies are discarded. This supports repeated reachability and status, not independent confirmation of a new administrator session or file access.

Test-7A-findings-retest.png

7B | Supplied analyst severity review

Prepared record / supplied original

The prepared page records six observations and a qualitative severity approach.



Anyaugo Space-Tech Ltd.

SECURITY CONSULTING | CLIENT GUIDANCE

Project 5 Findings Retest and Severity Review

Controlled web application exposure review lab

Test 07

Prepared analyst review

After testing

Retest result

Both headline findings were re-run from the testing machine and re-confirmed as reproducible: the administrator login bypass returned a valid session (HTTP 200) and the exposed file directory remained openly reachable (HTTP 200). Because the practice application is intentionally vulnerable and cannot be patched, this retest verifies that each finding reproduces on demand rather than confirming a fix. In a real engagement this stage would instead confirm that the client's remediation has closed the issue.

#	Finding	Severity	Why this rating
6A	Administrator login bypass (SQL injection)	Critical	Full admin takeover with no password, reachable by anyone. Highest impact, trivial to exploit.
6B	Sensitive files exposed in public /ftp directory	High	Backups and a password vault downloadable by anyone. Leads to credential compromise via offline follow-up.
—	Sensitive data inside login token (password hash)	Medium	Helps an attacker if a token leaks, but not directly exploitable on its own.
—	Missing security headers (no CSP / HSTS)	Low	Weakens defence-in-depth; enables other attacks rather than being one itself.
—	robots.txt discloses the hidden /ftp path	Info	Not a flaw itself; signposts a sensitive area straight to attackers.
—	Permissive CORS (Access-Control-Allow-Origin: *)	Low	Risky on sensitive APIs; low impact on a public storefront.

How severity is decided

Severity reflects **impact** × **ease of exploitation**. Critical means the worst outcome (full takeover) reachable with little effort by anyone. High means serious data exposure that needs some follow-up work. Medium and Low weaken defences or assist other attacks rather than breaking in directly. Informational items are not flaws in themselves but hand useful signposts to an attacker. Ratings guide the order of fixing: close Critical and High first.

Evidence label: Test-7B-Severity-Review

Status: all findings re-verified and rated on a single consistent scale

Project 5 controlled lab evidence

Evidence note: Preserved as supplied. Its claims about valid retest sessions, file downloads and inability to patch are qualified in the preceding explanation.

Test-7B-Severity-Review.png

Final Report

What the portfolio supports and what remains open

Overall outcome

The portfolio demonstrates a working two-machine web lab, automated target deployment, command-line traffic capture, endpoint discovery and a documented administrator-login bypass. A directory listing exposes potentially sensitive filenames. The evidence supports a useful capability demonstration rather than assurance over any real company's systems.

Strongest finding

Test 6A records authentication data returned from a crafted login request, followed by a decoded administrator identity. This is the most direct demonstration of a security failure. Its potential business consequence justifies urgent attention in an equivalent authorised client environment.

Supporting observations

The captures also show a password-hash field in a customer token, wildcard CORS and the absence of some headers from sampled HTTP responses. These are distinct observations with different prerequisites and confidence levels. They should not all be described as independently exploited vulnerabilities.

What has not been established

No cloud security review, data theft, vault cracking, host compromise, comprehensive isolation audit or successful remediation is demonstrated. The scope, severity and privacy pages are prepared records. The scan reports errors; the final retest captures only status codes.

Tools evidenced

VirtualBox records the VM checkpoints; Kali and Ubuntu provide the lab systems; Ansible deploys the target through SSH; Docker runs the application; curl captures HTTP exchanges; ffuf discovers candidate paths; shell text processing and Base64 decoding expose selected response content. The supplied files do not demonstrate use of Burp Suite or mitmproxy.

Decision for a real client

Prioritise the authentication defect, then validate the exposure and sensitivity of files. Assign fixes to the relevant owner, agree acceptance criteria and retest changed behaviour. The following pages provide a proposed priority register and delivery workflow, separate from work completed in this lab.

Findings and Priorities

Supplied ratings retained; confidence and next steps made explicit

Observation / rating	Evidence and confidence	Proposed action / owner
6A Login bypass Critical	Token returned; decoded admin identity. Privileged functions not exercised.	Prioritise query repair and meaningful session retest. Application developer.
6B Directory exposure High, provisional	Listing and sensitive-looking filenames shown. Individual download and content unverified.	Validate permitted access; remove or protect sensitive artifacts. Hosting / application owner.
Token data Medium	Password-hash field visible in customer payload. No cracking or forgery shown.	Remove unnecessary sensitive claims; inspect new tokens. Identity / application developer.
Security headers Low, contextual	No CSP / HSTS in sampled HTTP response; some protective headers are present.	Review production HTTPS and browser policy. Application / platform owner.
robots.txt path Informational	/ftp disclosed. This is a lead, not access control.	Protect the resource itself; review disclosed paths. Application owner.
Wildcard CORS Low, contextual	Allow-Origin: * visible; sensitive cross-origin read not demonstrated.	Review each endpoint and intended origins. API owner.

Status: No remediation is evidenced for any item. The supplied ratings are qualitative, not CVSS scores. The ordering above is a proposed work queue; the client would confirm impact, ownership and deadlines.

Remediation guidance: SQL injection [R2]; web-served backup files [R3]; JWT claims [R4]; headers [R5]; CORS [R6].

From Discovery to an Approved Fix

A practical handover for an authorised engagement

1 | Agree the engagement

Obtain written authority and agree targets, methods, timing, contacts and stop conditions. Include third-party and cloud boundaries explicitly. Confirm the evidence location and permitted AI use before handling restricted material. This is proposed client practice, not authority supplied by the lab record. [R1]

2 | Establish a reliable baseline

Verify target identity and expected access. Record the environment and normal login behaviour, preserve a baseline response, and confirm how to stop testing if the service is affected. Use controlled accounts and synthetic data where possible.

3 | Validate and report the loophole

Distinguish a scanner lead from a demonstrated issue. Capture enough evidence to show the affected boundary and explain potential business impact. For a serious authentication failure, notify the agreed contact promptly rather than waiting for the final report.

4 | Give the owner a concrete action

For each finding, record the affected function, evidence, confidence, impact, recommended correction and a responsible owner. The client decides change timing and risk acceptance. An assessor should not silently alter production just because a weakness was discovered.

5 | Retest the security outcome

After the owner confirms a change, repeat the approved case and inspect meaningful response content or behaviour. Check both the original failure and normal authorised use. Mark the result as resolved, partly resolved, unresolved or not retested, with supporting evidence.

6 | Close the engagement

Deliver the findings and limitations, remaining actions and any accepted risk. Close temporary access and manage evidence retention or deletion under the agreement. Keep the business owner's decisions distinguishable from the assessor's observations and recommendations.

Evidence Limits and Next Validation

A clear distinction between observed results and open questions

Area	Current evidence	Next validation
Lab boundary	Local addressing and successful ping; an additional Kali interface appears connected.	Review all adapters, routes and permitted egress.
Automation	Successful playbook recap and working storefront.	Review actual playbook and inventory; perform an approved rebuild if required.
Discovery	Size-filtered leads; 1,074 scan errors.	Review raw output and manually validate important and failed requests.
Authentication	Crafted login returns administrator identity in token.	Check approved harmless privilege use and post-fix behaviour.
File exposure	Directory names include backups and a vault-like filename.	Validate authorised direct access and sensitivity; do not infer contents.
Retest	Two HTTP 200 responses; bodies discarded.	Capture session and access behaviour after a documented change.
Cloud exposure	No cloud-platform evidence supplied.	Agree a separate scope and collect cloud-specific evidence.
Privacy / AI	Prepared recommendations and report-level distinctions.	Obtain client agreement and verify the actual workflow controls.

Claim supported: a documented web-application training exercise with an administrator-login bypass and directory filename exposure. Broader exploitation, production assurance and successful repair remain outside the demonstrated result.

Privacy and Responsible AI Use

Professional recommendations for client review

Why this belongs in the report

Security evidence can contain account details, tokens, internal names and business information. Responsible handling is part of professional delivery. This section describes proposed controls for client work; the prepared page is not proof that a client approved or implemented them.

1 | Agree the workspace and purpose

Record which AI service and workspace may be used, for what task and with which data. Permission to assess a system should not be assumed to include permission to disclose its information to an AI provider.

2 | Minimise shared information

Use synthetic examples or reviewed, sanitised extracts. Review screenshots as well as text for secrets and personal information. Preserve original evidence separately; if a sharing copy is redacted, label it and maintain its relationship to the original.

3 | Control access and provider handling

Agree named access, appropriate authentication, storage and retention. Check provider terms relevant to processing, training use and deletion. A paid subscription or familiar brand is not itself evidence that the required handling is in place.

4 | Keep a human accountable

Use AI to assist drafting and explanation, with an analyst checking every claim against source evidence. AI output must not invent findings, raise confidence without proof or declare a fix successful from an HTTP code alone. NIST's Generative AI Profile supports attention to privacy and human oversight. [R7]

5 | Record decisions and review disclosures

Keep the agreed purpose, permitted sharing, reviews and evidence-handling decisions. If information is shared outside the agreement, stop further disclosure and follow the agreed response and client-notification process.

How this PDF uses the principle

This report separates original screenshots, analyst interpretation and hypothetical scenarios. The source images remain unchanged, including visible lab authentication material. No client data-processing approval, privacy-enforcement tool or provider-compliance assessment is claimed.

9A | Client privacy and responsible AI use

Prepared record / supplied original

The supplied Anyaugo page sets out six recommendations covering workspace approval, sharing, access, review, provider terms and accountability.



PROJECT 5 / TEST 09 / AGENCY RECOMMENDATIONS

Client Privacy and Responsible AI Use

Our recommendation: keep client information inside an approved environment, use AI for agreed purposes only, and put a human review between any AI-assisted work and the client. The six practices below connect responsible AI use with data handling and clear accountability.

01 Agree the AI workspace

Use the client's approved AI environment, or a company-managed workspace the client signs off on. Record which AI service is used, for what purpose, and what data is allowed in it. Permission to test a system is separate from permission to share its information with an AI provider.

02 Limit what is shared

Feed the AI only synthetic examples or reviewed, sanitised extracts. Keep passwords, keys, session tokens, customer records and private code out of AI inputs unless a specific processing agreement covers them. Check screenshots and file names for hidden sensitive data too.

03 Control access

Use named accounts, multi-factor sign-in, and only the access the engagement needs. Separate client work from personal work and from other clients. Keep original evidence in access-controlled, encrypted storage.

04 Review and verify

Have a responsible analyst review AI-assisted findings and wording against the real evidence before anything reaches the client. AI drafts are a starting point, not a verdict. Retest fixes and record the outcome before declaring an issue resolved.

05 Check provider terms

Confirm data retention, whether inputs train future models, storage location, and third-party processing before sharing anything restricted. Agree return and deletion arrangements. A paid or well-known workspace does not by itself prove these protections.

06 Keep an accountable record

Record approvals, access granted, permitted disclosures, redactions and retest results. If information is exposed by accident, stop further sharing, preserve the relevant records and notify the agreed client contact. At closure, remove access and document evidence return or deletion under the agreed plan.

Project 5 uses a deliberately vulnerable practice application in a controlled lab. These are agency recommendations for client review and adoption; this exercise does not verify their implementation in a client environment. No real client credentials, production customer records, or active malicious code were used.

References: NIST AI 600-1 (2024), Generative AI Profile; NCSC guidance on unmanaged tools and shadow IT.

Evidence label: Test-9A-Privacy-And-AI-Use-Recommendations

Project 5 controlled lab evidence

Evidence note: Prepared agency recommendations for client consideration. This image is not evidence that the controls were deployed or audited.

Test-9A-Privacy-And-AI-Use.png

Provenance and Reading Limits

Keep the evidence and the interpretation traceable

What was reviewed

The Project05-Web-and-Cloud-Exposure-Review folder contains READ-ME-FIRST.md and 27 PNG image files across Tests 01-07 and 09. Test 08 was empty at review. The supplied Project 4 unified PDF was used as the presentation reference; its cover provides the existing Anyaugo logo. Nunito fonts are supplied in the project folder.

Image accounting

All 27 image files appear in this PDF. Three are prepared records: scope, severity review and privacy recommendations. The other 24 are lab screenshot files. Two pairs are byte-identical, so there are 25 unique images in total and 22 unique lab screenshots. Repeated files are retained in their original test contexts.

Preservation and captions

Source images are embedded without retouching or content cropping. New captions and explanatory notes sit outside the images. Wide screenshots use landscape pages; long prepared records use larger portrait pages to protect readability. The original font and content inside each image are preserved.

Evidence dates and source completeness

Several captures display 23-24 September 2026; the report was prepared on 24 September 2026. Clock synchronisation, capture authenticity and an end-to-end chain of custody were not independently verified. Command-referenced text logs, scan JSON, playbook and inventory files were not supplied.

How conflicting wording was handled

The README supplies the intended plain-language story. Where its wording exceeds the screenshots, this report states the narrower supported conclusion. Examples include complete isolation, universal file downloadability, status-only retesting and a claim that the lab cannot be patched. No source file was edited to hide those differences.

Publisher and use

Prepared for the Anyaugo Space-Tech Ltd. portfolio as a controlled-lab capability demonstration. Branding identifies the publisher and does not confer client authorization, external certification or assurance over production systems. External references support recommendations; they do not independently validate this lab.

References

Primary sources checked on 24 September 2026

R1 | NIST SP 800-115

Technical Guide to Information Security Testing and Assessment (2008). Assessment planning, rules of engagement and reporting.

[Open primary source](#)

R2 | OWASP SQL Injection Prevention Cheat Sheet

Parameterised queries and least-privilege database access.

[Open primary source](#)

R3 | OWASP Web Security Testing Guide

Review Old Backup and Unreferenced Files for Sensitive Information. Web-served artifacts and configuration review.

[Open primary source](#)

R4 | OWASP JSON Web Token Cheat Sheet

Signed claims, confidentiality distinctions and token security.

[Open primary source](#)

R5 | OWASP HTTP Headers Cheat Sheet

Security headers and their appropriate application context.

[Open primary source](#)

R6 | OWASP REST Security Cheat Sheet

Endpoint access control and cross-origin policy.

[Open primary source](#)

R7 | NIST AI 600-1

Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (2024). Privacy and human oversight.

[Open primary source](#)

References inform the recommendations; they do not certify the lab or grant testing permission. The project README, original screenshots and supplied Project 4 report are the local source materials. Nunito is used from the supplied font package.